Cloud-Based SIEM for HIPAA Compliant EHR Migration

Mckenzie L. Savage

Western Governors University

WESTERN GOVERNORS UNIVERSITY

Table of Contents

A. Proposal Overview

A.1 Problem Summary

Magnolia Family Medicine is a medium-sized family healthcare practice with approximately 80 employees in the Upstate of South Carolina. The organization operates eClinicalWorks as its on-premises electronic health record (EHR) system with their Active Directory (AD) hosted in Azure Active Directory. The practice manager and primary point of contact, Daisy Lane, has acknowledged that their existing on-premises infrastructure lacks compliance with the Health Insurance Portability and Accountability Act (HIPAA) due to the absence of centralized logging and security monitoring.

While clinical leadership has expressed concerns about transitioning to a cloud environment, they have recently agreed to migrate their EHR system to the cloud. Management now understands the improved functionality, scalability, and security features offered by the cloud-based version of eClinicalWorks. The physicians and administrative team are committed to maintaining HIPAA compliance throughout the migration process and the ongoing management of their cloud-hosted systems.

To bridge the security gaps, Daisy Lane contacted FloraSec Technologies, a consulting firm specializing in cloud-based cybersecurity solutions for healthcare organizations. FloraSec Technologies will work closely with Magnolia Family Medicine to find a comprehensive and compliant path forward.

A.2 IT Solution

After carefully reviewing Magnolia Family Medicine's existing on-premises infrastructure, security protocols, and compliance posture, FloraSec Technologies suggests implementing Microsoft Sentinel- a cloud-based Security Information and Event Management (SIEM) solution. This platform will centralize logging and support regulatory compliance.

The solution involves deploying Microsoft Sentinel to collect and analyze security data from the practice's systems, including legacy on-premises infrastructure and emerging cloud-based services. Microsoft Sentinel will enable real-time threat monitoring and detection for Magnolia's systems. This solution will allow HIPAA-aligned data governance practices so that Magnolia Family Medicine can remain confident in its security in the hybrid environment.

A.3 Implementation Plan

To implement the proposed Microsoft Sentinel solution, FloraSec Technologies will lead a structured rollout in close collaboration with Magnolia Family Medicine's internal IT and leadership team. FloraSec will begin by conducting a detailed planning session with leadership at the practice to identify all data sources- both on-premises and cloud-based- to define HIPAA-aligned monitoring practices and finalize all requirements. FloraSec will provision a secure Azure Log Analytics workspace to collect and store log data. Once configured, FloraSec will enable Microsoft Sentinel within the workspace. FloraSec will work closely with Magnolia's IT team to determine dashboard preferences, incident response rules, and role-based access controls to ensure secure access to sensitive security information. For Magnolia's on-premises infrastructure, FloraSec will guide the IT team in deploying and configuring Azure Monitor agents on servers and devices to forward security logs to Sentinel, ensuring comprehensive monitoring across both environments.

FloraSec will enable the native data connectors between Azure Active Directory and Microsoft Sentinel to begin ingesting identity and access logs. This connection will enable FloraSec to implement analytics rules and alert logic within the Microsoft Sentinel dashboard to align Magnolia's technical environment with HIPAA compliance requirements. FloraSec will deliver hands-on training to Magnolia's IT staff. The training would focus on using Sentinel's detection, investigation, and response capabilities effectively. Finally, FloraSec will transition the environment into production and support the practice during stabilization. This includes assistance with troubleshooting, fine-tuning alert rules, and reinforcing knowledge transfer to ensure a smooth handover of responsibilities.

A.3.a Justification of Plan

To ensure the successful deployment of Microsoft Sentinel at Magnolia Family Medicine, this implementation plan is built around a well-established SIEM deployment framework known as EDO4SIEM (Evaluation, Deployment, Operation for Security Information, and Event Management). EDO4SIEM, developed by Rosenberg et al.(2023), offers a step-by-step waterfall framework for evaluating, deploying, and managing SIEM systems. It's especially useful in complex healthcare settings where careful planning, thorough documentation, and regulatory compliance are essential.

Using EDO4SIEM helps ensure a clear understanding of Magnolia's current infrastructure, supporting safe data handling as they move from on-premises to a hybrid setup. The framework also guides the process of identifying all important data sources, setting up customized monitoring and alerting, and putting in place procedures for ongoing operations. Ultimately, the structured and vendor-neutral nature of EDO4SIEM makes it an ideal guide for deploying Microsoft Sentinel at Magnolia Family Medicine.

B. Review of Other Work and Works Informing Design

B1. Review of Work I

The U.S. Department of Health and Human Services (HHS) outlines the Health Insurance Portability and Accountability Ace (HIPAA) Security Rule in 45 CFR § 164.312, which sets the standard for protecting ePHI. It requires covered organizations, such as healthcare providers, to implement access and audit controls. Specifically, the rule mandates that only authorized individuals can access sensitive health information and that all access is logged and monitored (HHS, 2025).

Magnolia Family Medicine holds the duty to uphold HIPAA technical safeguard requirements. Implementing a SIEM like Microsoft Sentinel would align with that duty by providing a tool that monitors access, provides logging/auditing, and protects ePHI through other technical means.

B2. Review of Work II

Jeffrey Marron created a comprehensive guide for healthcare organizations on implementing the HIPAA Security Rule, as outlined in NIST Special Publication 800-66 Revision 2 (2024). The publication breaks down HIPAA's administrative, physical, and technical requirements. Furthermore, it offers practical steps for compliance.

This resource supports the goals of the proposed project by offering a federally endorsed framework for safeguarding ePHI. FloraSec Technologies will use recommendations from the publication to develop security controls that ensure HIPAA compliance through the Microsoft Sentinel implementation.

B3. Review of Work III

The Microsoft Sentinel Deployment Overview provided by Microsoft outlines the structured phases involved in the planning and deploying of the SIEM solution. It breaks down key activities such as configuring data connectors and access controls. The document explains the proper setup and tips for fine-tuning analytics rules (Microsoft, 2025).

The resource is relevant to the proposed project in outlining the technical requirements for a successful SIEM deployment. These guidelines will help FloraSec Technologies implement Sentinel using vendor-recommended best practices.

B4. Review of Work IV

Richard Diver, Gary Bushey, and John Perkins' book *Microsoft Sentinel in Action* (2022) provides an in-depth guide to designing, deploying, and managing Microsoft Sentinel. The book covers the best practices and procedures for implementing and managing the SIEM. It also outlines how Sentinel integrates natively within Microsoft environments, notably Azure Active Directory and Microsoft 365.

This work is relevant to the proposed project because it gives detailed insight into configuring Microsoft Sentinel within a native Microsoft ecosystem. The book supports a seamless integration for organizations already operating in a Microsoft environment. FloraSec will use the recommendations and guidelines provided in this book to inform the configuration and deployment of Sentinal at Magnolia Family Medicine.

C. Project Rationale

Magnolia Family Medicine has a critical need to enhance its security posture to ensure HIPAA compliance. Microsoft Sentinel allows centralized and real-time visibility of security events on all systems. This will help the practice quickly identify and respond to potential security threats, protecting sensitive ePHI from unauthorized access.

For example, if an unusual access pattern to eClinicalWorks in the cloud is detected- such as multiple failed log-in attempts from an unfamiliar location- Microsoft Sentinel can alert the IT team immediately. This allows the team to investigate potential cloud account compromises to take swift action and prevent breaches.

This project is achievable because FloraSec Technologies has proven experience deploying SIEM solutions in healthcare environments. Using the EDO4SIEM framework to guide implementation ensures a clear, step-by-step plan of action that meets Magnolia Family Practice's needs (Rosenberg et al., 2023).

D. Current Project Environment

Magnolia Family Medicine initially had concerns about moving their eClinicalWorks systems to the cloud because they did not believe cloud environments could fully protect sensitive data. Patient privacy is a core value, and they hesitated to risk exposing ePHI in the cloud without safeguards. Microsoft Sentinel is the right tool to provide that data protection and give the practice the confidence to move forward with the hybrid environment. It gives their team real-time visibility into security events so they can quickly detect and respond to potential threats. Furthermore, this solution supports their values by enforcing role-based access controls. Supporting Magnolia Family Medicine in their beliefs that only the right people have access to sensitive data. Magnolia's transition to a hybrid environment is a natural next step for their strategy in honoring their commitment to patient privacy.

E. Methodology

This project will follow the Waterfall methodology, a phase-oriented approach that will follow sequentially defined steps. Given the structured nature of implementing a SIEM solution in healthcare, Waterfall enables precise planning and documentation throughout each project lifecycle phase.

To guide Flora Sec through the SIEM implementation, this project will adopt the EDO4SIEM framework developed by Rosenberg et al. (2023). It outlines best practices for evaluating, deploying, and operating SIEM systems across different organization types to ensure alignment with business objectives and risk posture. By adopting the EDO4SIEM model, FloraSec will have a clear roadmap for implementation. They will identify relevant data sources, configure event collection, establish correlation rules, and finally, maintain ongoing monitoring and response.

These activities will be aligned with the waterfall phases to make sure every project task gets done. Combining these methods gives a strong foundation for deploying Microsoft Sentinel that supports HIPAA compliance and keeps the project on track.

F. Project Goals, Objectives, and Deliverables

F1. Goals, Objectives, and Deliverables Table

Goal	Supporting Objectives	Deliverables Enabling the Project Objectives
1. Secure Electronic Protected Health Information (ePHI) for HIPAA Compliance	1.A. Protect ePHI in transit and at rest	1.A.I. Configure secure data connectors for encrypted data transmission.
		1.A. II. Provision and monitor the Azure Log Analytics Workspace.
	1.B. Restrict and audit access to sensitive access	1.B.I. Implement role-based access controls (RBAC) within Sentinel.
		1.B. II. Configure auditing and reporting rules to track access to ePHI-related logs.
2. Centralize Security Log Management for the Hybrid Environment	2.A. Integrate on-premises and cloud-based systems	2.A.I. Install and configure Azure Monitor agents on-premises.
		2.A. II. Connect cloud services to Sentinel via native connectors
		2.B.I. Identify and register all relevant log sources.

	2.B. Ensure comprehensive event logging	2.B. II. Enable ingestion rules for real-time historical data.
3. Build IT Team Readiness to Ensure Long-Term Operational Stability	3.A. Train staff on Microsoft Sentinal features	3.A.I. Deliver instructor-led training sessions on threat detection and investigation.
		3.A.II. Provide written job aids and quick-reference guides for key workflows.
	3.B. Prepare IT staff to independently maintain and operate the SIEM environment	3.B.I. Conduct a hands-on knowledge transfer session with Magnolia IT staff.
		3.B.II. Develop a detailed operations runbook covering routine maintenance, alert tuning, and escalation procedures.

F2. Goals, Objectives, and Deliverables Descriptions

Goal 1 centers on securing electronic protected health information (ePHI) to meet HIPAA requirements. This is achieved by protecting sensitive data during transmission and storage by configuring encrypted data connectors (1.A.I) and continuously monitoring using Azure Log Analytics Workspace (1.A.II). Access to ePHI is also controlled and audited by implementing role-based access controls within Microsoft Sentinel (1.B.I) and setting up auditing and reporting rules to track access to sensitive logs (1.B.II). These measures follow the technical safeguards mandated by the HIPAA Security Rule, particularly 45 CFR §164.312, which requires access controls, audit controls, and transmission security to protect ePHI (HHS, 2025).

Goal 2 focuses on centralizing security log management across on-premises infrastructure and cloud services. This includes deploying Azure Monitor agents on local systems (2.A.I) and establishing connections to Microsoft Sentinel through native cloud connectors (2.A.II). It also involves identifying and registering all relevant log sources (2.B.I) and enabling ingestion rules to capture real-time and historical security events (2.B.II). Centralizing these logs improves overall visibility and enhances the ability to detect and respond to threats within the hybrid environment.

Goal 3 focuses on preparing the IT team to run and maintain Microsoft Sentinel smoothly over time. This involves leading training sessions that teach how to detect and investigate threats (3.A.I) and providing easy-to-use job aids and quick guides to help the team remember key tasks (3.A.II). The plan also includes hands-on knowledge transfer to build practical experience (3.B.I) and create a clear operations runbook covering regular maintenance, tuning alerts, and escalations (3.B.II). This way, the IT staff will be confident in managing the SIEM system and maintaining security.

G. Project Timeline with Milestones

Milestone	Duration (hours or days)	Projected Start Date	Anticipated End Date
1. Establish Contract and Conduct Project Planning Session	5 days	August 4, 2025	August 8, 2025
2. Asset and Log Mapping Phase	5 days	August 11, 2025	August 15, 2025
3. Provision Azure Log Analytics Workspace/ Enable Microsoft Sentinel	3 days	August 18, 2025	August 20, 2025
4. Configure Dashboards, Alert Rules, and RBAC	6 days	August 21, 2025	August 28, 2025
5. Deploy Azure Monitor Agents on On-Premises Infrastructure	5 days	August 29, 2025	September 4, 2025
6. Connect Cloud Services and Enable Native Data Connectors	3 days	September 5, 2025	September 9, 2025
7. Implement Analytics Rules/Alert Logic in Sentinel	3 days	September 10, 2025	September 12, 2025

8. Develop/ Deliver Quick-Reference Guides and Operations Run-Book	5 days	September 15, 2025	September 19, 2025
9. Deliver Hands-On Training to Magnolia IT Staff	5 days	September 22, 2025	September 26, 2025
10. Go-Live	1 day	September 29, 2025	September 29, 2025
11. Stabilization Support	4 days	September 30, 2025	October 3, 2025
12. Final Knowledge Transfer	3 days	October 6, 2025	October 8, 2025

H. Outcome

This project aimed to fully deploy Microsoft Sentinel across Magnolia Family Medicine's hybrid environment within about 65 days of kick-off. By then, the system should collect security data from all resources with dashboards and alerts functioning properly. Another clear sign of success will be the IT teams' ability to use Sentinel independently- logging in, checking alerts, and easily responding to incidents.

FloraSec Technologies will document each significant step outlined in the project timeline to track progress. After training, the IT department will complete hands-on tasks to show that they can manage alerts and respond correctly. Feedback will also be collected from the IT team, practice administrator, and clinicians to determine their confidence and satisfaction with the system. That feedback, combined with system logs and testing reports, will measure how well the rollout went and what adjustments are needed post go live. This outcome not only meets the project's technical goals but also means Magnolia Family Medicine can maintain HIPAA compliance to continue protecting their patient's sensitive data.

References

Diver, R., Bushey, G., & Perkins, J. (2022). *Microsoft Sentinel in action: Architect, design, implement, and operate Microsoft Sentinel as the core of your security solutions* (2nd ed.). Packt Publishing.

Marron, J. (2024). *Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A cybersecurity resource guide* (NIST Special Publication 800-66r2). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-66

Microsoft Corporation. (n.d.). *Overview of deployment for Microsoft Sentinel*. Microsoft Learn. Retrieved June 9, 2025, from https://learn.microsoft.com/en-us/azure/sentinel/deploy-overview

Rosenberg, M., Schneider, B., Scherb, C., & Asprion, P. M. (2023). *EDO4SIEM – A procedure model for the implementation of Security Information and Event Management systems in organisations*. *IADIS International Journal on Computer Science and Information Systems, 19*(1), 31–47.

U.S. Department of Health and Human Services (HHS). (2025). *45 CFR §164.312 - Technical safeguards.* Electronic Code of Federal Regulations. https://www.ecfr.gov/current/title-45/part-164/section-164.312